

## Swoo Tech Mart — API Endpoint Specification

Swoo Tech Mart is a full-stack e-commerce platform designed to provide secure and scalable online shopping functionality. The platform supports user authentication, product discovery, product variants, shopping cart, wishlist, checkout, order management, reviews, and online payments. The backend is implemented using Spring Boot and exposes RESTful APIs consumed by the React frontend.

### API Overview

The [Swoo Tech Mart](#) backend exposes RESTful APIs that support customer-facing shopping functionality and administrative operations. APIs are organized by business domain and use role-based access control where required. Public endpoints support product discovery and guest shopping, while authenticated endpoints provide account, cart, wishlist, checkout, order, payment, and review functionality.

| Item             | Details                    |
|------------------|----------------------------|
| Project          | Swoo Tech Mart             |
| Document         | API Endpoint Specification |
| API Version      | v1.0                       |
| Backend          | Spring Boot                |
| Frontend         | React                      |
| Database         | PostgreSQL                 |
| Authentication   | JWT + OAuth 2.0            |
| API Architecture | RESTful                    |

### Authentication Legend

| Type    | Meaning                                                    |
|---------|------------------------------------------------------------|
| Public  | No authentication required                                 |
| Private | Valid JWT/access token required.                           |
| USER    | Authenticated customer                                     |
| ADMIN   | Administrative privileges required                         |
| Owner   | User can access only their own resource                    |
| Webhook | Authentication handled through payment-provider signature. |

### API Response Format

|                                     |
|-------------------------------------|
| <pre>{<br/>  "success": true,</pre> |
|-------------------------------------|

```
"message": "Product retrieved successfully",
"data": {}
}
```

And an error response:

```
{
  "success": false,
  "message": "Product not found",
  "errorCode": "PRODUCT_NOT_FOUND",
  "timestamp": "2026-09-03T12:00:00Z"
}
```

### HTTP Status Codes

| Status                    | Usage                                |
|---------------------------|--------------------------------------|
| 200 OK                    | Successful GET/PUT/PATCH             |
| 201 Created               | Resource successfully created        |
| 204 No Content            | Successful deletion/no response body |
| 400 Bad Request           | Invalid request                      |
| 401 Unauthorized          | Missing/invalid authentication       |
| 403 Forbidden             | Insufficient permissions             |
| 404 Not Found             | Resource doesn't exist               |
| 409 Conflict              | Resource/state conflict              |
| 422 Unprocessable         | Validation/business-rule failure     |
| 500 Internal Server Error | Unexpected server error              |

### API Module Summary

| Module          | Purpose                                  |
|-----------------|------------------------------------------|
| Authentication  | Registration, login, JWT refresh, OAuth2 |
| User            | Profile and account management           |
| Address         | Shipping/billing address management      |
| Catalog         | Categories, brands, tags, products       |
| Variants        | Product variants and attributes          |
| Reviews         | Product reviews and eligibility          |
| Wishlist        | Wishlist management                      |
| Cart            | Guest and authenticated shopping carts   |
| Orders          | Order creation and management            |
| Payments        | Payment initiation and webhooks          |
| Recently Viewed | Recently viewed products                 |

|                 |                              |
|-----------------|------------------------------|
| Checkout        | Checkout summary and pricing |
| Product Filters | Product filtering metadata   |

## API End Points

### Authentication & Identity

Backing tables: User, Role , user\_roles, RefreshToken

| Method | Endpoint                              | Auth    | Role | Params / Body                           | Description                                                                                                               |
|--------|---------------------------------------|---------|------|-----------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| POST   | /api/auth/register                    | Public  |      | Body: fullName, email, password         | Creates a new user account, securely hashes the password, and disables the account until email verification is completed. |
| POST   | /api/auth/login                       | Public  |      | Body: email, password                   | Validates credentials, issues JWT access token + refresh token (persisted in RefreshToken ).                              |
| POST   | /api/auth/refresh-token               | Public  |      | Body: refreshToken                      | Validates the refresh token, issues a new access token, and rotates the refresh token.                                    |
| POST   | /api/auth/logout                      | Private | ANY  | Body: refreshToken                      | Deletes the matching RefreshToken row so it can't be reused.                                                              |
| GET    | /api/auth/oauth2/authorize/{provider} | Public  |      | Path: provider (google, facebook, etc.) | Redirects to OAuth2.0 provider consent screen (Spring Security OAuth2 client handles this route automatically).           |
| GET    | /api/auth/oauth2/callback/{provider}  | Public  |      | Path: provider ;<br>Query: code, state  | Spring Security OAuth2 client handles this route automatically.                                                           |
| POST   | /api/auth/verify-email                | Public  |      | Body: token                             | Verifies the user's email address using the provided verification token and activates email verification status.          |
| POST   | /api/auth/forgot-password             | Public  |      | Body: email                             | Initiates the password-reset process by                                                                                   |

|      |                          |        |  |                          |                                                                              |
|------|--------------------------|--------|--|--------------------------|------------------------------------------------------------------------------|
|      |                          |        |  |                          | validating the email and sending a password-reset token or link.             |
| POST | /api/auth/reset-password | Public |  | Body: token, newPassword | Validates the password-reset token and securely updates the user's password. |

## User Account / Profile

Backing table: User

| Method | Endpoint                         | Auth    | Role  | Params / Body                      | Description                                                                                                            |
|--------|----------------------------------|---------|-------|------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| GET    | /api/users/me                    | Private | ANY   |                                    | Returns the logged in user's profile (from JWT subject). Powers your "Account Info" page.                              |
| PUT    | /api/users/me                    | Private | ANY   | Body: fullName, avatarUrl          | Updates the authenticated user's profile information.                                                                  |
| PATCH  | /api/users/me/password           | Private | ANY   | Body: currentPassword, newPassword | Dedicated password change flow; re-check current password server side.                                                 |
| POST   | /api/users/me/avatar             | Private | ANY   | Multipart file                     | Uploads avatar image, updates User.avatarUrl.                                                                          |
| DELETE | /api/users/me                    | Private | ANY   |                                    | Soft-delete / deactivate own account (set enabled=false) rather than hard delete, to preserve Order history integrity. |
| GET    | /api/admin/users                 | Private | ADMIN | Query: page, size, search          | Admin user list/search — needed for a back-office.                                                                     |
| GET    | /api/admin/users/{userId}        | Private | ADMIN | Path: userId                       | Admin view of a single user (support/moderation use case)                                                              |
| PATCH  | /api/admin/users/{userId}/roles  | Private | ADMIN | Body: roleIds[]                    | Assigns/revokes roles via user_roles.                                                                                  |
| PATCH  | /api/admin/users/{userId}/status | Private | ADMIN | Body: enabled                      | Enable/disable a user account (ban/unban).                                                                             |

## Address Book

Backing table: Address

| Method | Endpoint | Auth | Role | Params / Body | Description |
|--------|----------|------|------|---------------|-------------|
|--------|----------|------|------|---------------|-------------|

|        |                             |                 |     |                                                                                                    |                                                                                                                                              |
|--------|-----------------------------|-----------------|-----|----------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|
| GET    | /api/addresses              | Private (Owner) | ANY |                                                                                                    | Lists all addresses for the logged-in user — populates the "My Addresses" account page.                                                      |
| GET    | /api/addresses/{id}         | Private (Owner) | ANY | Path: id                                                                                           | Fetches one address;                                                                                                                         |
| POST   | /api/addresses              | Private (Owner) | ANY | Body: recipientName, line1, line2, city, state, postalCode, country, type, isDefault               | Adds a new address. If isDefault=true, unset the previous default in the same transaction.                                                   |
| PUT    | /api/addresses/{id}         | Private (Owner) | ANY | Path: id ;<br>Body: recipientName, line1, line2, city, state, postalCode, country, type, isDefault | Updates an existing address. If isDefault=true, the previous default address is unset within the same transaction.                           |
| DELETE | /api/addresses/{id}         | Private (Owner) | ANY | Path: id                                                                                           | Removes an address if it is not required by an existing order. Historical orders retain their address information through address snapshots. |
| PATCH  | /api/addresses/{id}/default | Private (Owner) | ANY | Path: id                                                                                           | Sets this address as default, clears the flag on others.                                                                                     |

## Catalog — Categories, Brands, Tags

Backing tables: Category , Brand , Tag , product\_tags

| Method | Endpoint                   | Auth    | Role  | Params / Body                                     | Description                                                                    |
|--------|----------------------------|---------|-------|---------------------------------------------------|--------------------------------------------------------------------------------|
| GET    | /api/categories            | Public  |       | Query: parentId? (omit for top-level)             | Returns category tree/list — powers nav menu and category showcase components. |
| GET    | /api/categories/{slug}     | Public  |       | Path: slug                                        | Single category detail, used when landing on a category page.                  |
| POST   | /api/admin/categories      | Private | ADMIN | Body: name, slug, parentCategoryId?               | Creates a category (self-referencing for subcategories).                       |
| PUT    | /api/admin/categories/{id} | Private | ADMIN | Path: id ;<br>Body: name, slug, parentCategoryId? | Edits a category.                                                              |
| DELETE | /api/admin/categories/{id} | Private | ADMIN | Path: id                                          | Deletes a category.                                                            |
| GET    | /api/brands                | Public  |       | Query: search?                                    | Lists brands — for brand filter chips/logos.                                   |
| GET    | /api/brands/{slug}         | Public  |       | Path: slug                                        | Brand detail (e.g. a brand storefront page).                                   |
| POST   | /api/admin/brands          | Private | ADMIN | Body: name, slug, logoUrl                         | Creates a brand.                                                               |
| PUT    | /api/admin/brands/{id}     | Private | ADMIN | Path: id ;                                        | Edits a brand.                                                                 |

|        |                        |         |       |                           |                                                           |
|--------|------------------------|---------|-------|---------------------------|-----------------------------------------------------------|
|        |                        |         |       | Body: name, slug, logoUrl |                                                           |
| DELETE | /api/admin/brands/{id} | Private | ADMIN | Path: id                  | Deletes a brand.                                          |
| GET    | /api/tags              | Public  |       |                           | Lists all tags (e.g. "New", "Best Seller") for filter UI. |
| POST   | /api/admin/tags        | Private | ADMIN | Body: label               | Creates a tag.                                            |
| DELETE | /api/admin/tags/{id}   | Private | ADMIN | Path: id                  | Deletes a tag (cascades product_tags rows).               |

## Catalog — Products

Backing tables: Product, ProductImage, ProductHighlight, ProductDescription, ProductDescriptionImage

| Method | Endpoint                                          | Auth    | Role  | Params / Body                                                                                         | Description                                                                                              |
|--------|---------------------------------------------------|---------|-------|-------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| GET    | /api/products                                     | Public  |       | Query: categoryId?, brandId?, tag?, minPrice?, maxPrice?, stockStatus?, isNew?, sort?, page, size, q? | Main product listing/search Endpoint.                                                                    |
| GET    | /api/products/{slug}                              | Public  |       | Path: slug                                                                                            | Full product detail: images, highlights, description blocks, variants summary — powers /product details. |
| GET    | /api/products/{id}/related                        | Public  |       | Path: id ;<br>Query: limit?                                                                           | Related products.                                                                                        |
| POST   | /api/admin/products                               | Private | ADMIN | Body: sku, title, slug, categoryId, brandId, stockStatus, isNew, tagIds[]                             | Creates a base product record.                                                                           |
| PUT    | /api/admin/products/{id}                          | Private | ADMIN | Path: id ;<br>Body: sku, title, slug, categoryId, brandId, stockStatus, isNew, tagIds[]               | Updates a product.                                                                                       |
| DELETE | /api/admin/products/{id}                          | Private | ADMIN | Path: id ;                                                                                            | Deletes/archives a product.                                                                              |
| POST   | /api/admin/products/{id}/images                   | Private | ADMIN | Path: id ;<br>Body/Multipart: url or file, sortOrder                                                  | Adds a ProductImage (gallery/carousel images).                                                           |
| DELETE | /api/admin/products/{id}/images/{imageId}         | Private | ADMIN | Path: id, imageId                                                                                     | Removes a product image.                                                                                 |
| PUT    | /api/admin/products/{id}/images/reorder           | Private | ADMIN | Body: [{imageId, sortOrder}]                                                                          | Bulk reorders gallery images.                                                                            |
| POST   | /api/admin/products/{id}/highlights               | Private | ADMIN | Path: id ;<br>Body: text, sortOrder                                                                   | Adds a bullet-point highlight (e.g. spec callouts).                                                      |
| DELETE | /api/admin/products/{id}/highlights/{highlightId} | Private | ADMIN | Path: id, highlightId                                                                                 | Removes a highlight line.                                                                                |
| GET    | /api/products/{id}/description                    | Public  |       | Path: id                                                                                              | Returns the rich ProductDescription                                                                      |

|        |                                                                          |         |       |                                                       |                                                        |
|--------|--------------------------------------------------------------------------|---------|-------|-------------------------------------------------------|--------------------------------------------------------|
|        |                                                                          |         |       |                                                       | n block + its images                                   |
| POST   | /api/admin/products/{id}/description/sections                            | Private | ADMIN | Path: id;<br>Body: title, body, sortOrder             | Adds Product description section.                      |
| PUT    | /api/admin/products/{id}/description/sections/{sectionId}                | Private | ADMIN | Path: id, sectionId;<br>Body: title, body, sortOrder  | Update a description section.                          |
| DELETE | /api/admin/products/{id}/description/sections/{sectionId}                | Private | ADMIN | Path: id, sectionId;                                  | Delete a description section.                          |
| POST   | /api/admin/products/{id}/description/sections/{sectionId}/images         | Private | ADMIN | Path: id ;<br>Body/Multipart: url, altText, sortOrder | Adds an inline image used inside the description body. |
| DELETE | /api/admin/products/{id}/description/sections/{sectionId}/images/{imgId} | Private | ADMIN | Path: id, imgId                                       | Removes a description image.                           |

## Catalog — Variants & Attributes

Backing tables: ProductVariant , AttributeType , AttributeValue, ProductVariantAttribute , ProductVariantImage

| Method | Endpoint                                         | Auth    | Role  | Params / Body                                                           | Description                                                                                                |
|--------|--------------------------------------------------|---------|-------|-------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| GET    | /api/products/{id}/variants                      | Public  |       | Path: id                                                                | Returns all available variants for a product, including attribute combinations, price, and stock quantity. |
| GET    | /api/variants/{variantId}                        | Public  |       | Path: variantId                                                         | Single variant detail (used to re-fetch price/stock when the user changes a selector).                     |
| POST   | /api/admin/products/{id}/variants                | Private | ADMIN | Path: id ;<br>Body: sku, price, stockQty, imageUrl, attributeValueIds[] | Creates a variant + its ProductVariantAttribute join rows in one call.                                     |
| PUT    | /api/admin/variants/{variantId}                  | Private | ADMIN | Path: variantId ;<br>Body: sku, price, stockQty, imageUrl               | Updates price/stock/sku for a variant.                                                                     |
| DELETE | /api/admin/variants/{variantId}                  | Private | ADMIN | Path: variantId                                                         | Deletes a variant (block if referenced by existing OrderItems — prefer soft-disable).                      |
| POST   | /api/admin/variants/{variantId}/images           | Private | ADMIN | Path: variantId                                                         | Adds a ProductVariantImage                                                                                 |
| DELETE | /api/admin/variants/{variantId}/images/{imageId} | Private | ADMIN | Path: variantId, imageId                                                | Removes a variant-specific image.                                                                          |
| GET    | /api/attribute-types                             |         |       |                                                                         | Lists global attribute types (e.g. "Color", "Size") — used by admin variant-builder UI                     |
| POST   | /api/admin/attribute-types                       | Private | ADMIN | Body: name                                                              | Creates a new attribute type.                                                                              |
| GET    | /api/attribute-types/{id}/values                 | Public  |       | Path: id                                                                | Lists values for a type (e.g. Color → Red, Blue, Black).                                                   |
| POST   | /api/admin/attribute-types/{id}/values           | Private | ADMIN | Path: id ; Body: label, value                                           | Adds a new attribute value under a type.                                                                   |

|        |                                  |         |       |          |                                                             |
|--------|----------------------------------|---------|-------|----------|-------------------------------------------------------------|
| DELETE | /api/admin/attribute-values/{id} | Private | ADMIN | Path: id | Deletes an attribute value (guard against in-use variants). |
|--------|----------------------------------|---------|-------|----------|-------------------------------------------------------------|

## Reviews

Backing table: Review

| Method | Endpoint                              | Auth                     | Role       | Params / Body                                                    | Description                                                                                           |
|--------|---------------------------------------|--------------------------|------------|------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------|
| GET    | /api/products/{id}/reviews            | Public                   |            | Path: id ;<br>Query: page, size, sort? (newest, highest, lowest) | Paginated reviews for a product, plus aggregate rating — feeds the reviews section on product detail. |
| POST   | /api/products/{id}/reviews            | Private                  | USER       | Path: id ;<br>Body: rating, body                                 | Creates a review for the specified product using the authenticated user's rating and review content.  |
| PUT    | /api/reviews/{id}                     | Private (Owner)          | USER       | Path: id ;<br>Body: rating, body                                 | Edits own review                                                                                      |
| DELETE | /api/reviews/{id}                     | Private (Owner or ADMIN) | USER/ADMIN | Path: id                                                         | Deletes own review, or admin moderates/removes any review.                                            |
| GET    | /api/products/{id}/review-eligibility | Private (Owner)          | USER       | Path: id                                                         | frontend knows whether to show "Write a review," "Edit your review," or nothing.                      |

## Wishlist

Backing tables: Wishlist, WishlistItem

| Method | Endpoint                        | Auth            | Role | Params / Body    | Description                                                                                                                                   |
|--------|---------------------------------|-----------------|------|------------------|-----------------------------------------------------------------------------------------------------------------------------------------------|
| GET    | /api/wishlist                   | Private (Owner) | ANY  |                  | Returns the logged-in user's wishlist with product summaries — powers /wishlist . Lazily create the Wishlist row on first use if none exists. |
| POST   | /api/wishlist/items             | Private (Owner) | ANY  | Body: productId  | Adds a WishlistItem . Return 409/no-op if already present.                                                                                    |
| DELETE | /api/wishlist/items/{productId} | Private (Owner) | ANY  | Path: productId; | Removes a product from the wishlist (this is                                                                                                  |



|        |               |                 |     |  |                                     |
|--------|---------------|-----------------|-----|--|-------------------------------------|
|        |               |                 |     |  | your heart-icon toggle-off action). |
| DELETE | /api/wishlist | Private (Owner) | ANY |  | Clears the entire wishlist.         |

## Cart

Backing tables: Cart , CartItem

| Method | Endpoint                 | Auth                   | Role | Params / Body                                     | Description                                                                                                                     |
|--------|--------------------------|------------------------|------|---------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| GET    | /api/cart                | Public/Private         | ANY  | Header: Authorization?<br>or<br>Cookie: sessionId | Returns current cart contents. Supports guest carts via sessionId and logged-in carts via userId — merge logic needed on login. |
| POST   | /api/cart/items          | Public/Private         | ANY  | Body: productId, variantId, quantity              | Adds an item; snapshots unitPriceSnapshot from the variant's current price at add-time.                                         |
| PATCH  | /api/cart/items/{itemId} | Public/Private (Owner) | ANY  | Path: itemId ;<br>Body: quantity                  | Updates quantity of a single CartItem . Re-validate against ProductVariant.stockQty .                                           |
| DELETE | /api/cart/items/{itemId} | Public/Private (Owner) | ANY  | Path: itemId;                                     | Removes one line item from the cart.                                                                                            |
| DELETE | /api/cart                | Public/Private (Owner) | ANY  |                                                   | Empties the entire cart (e.g. after a successful order).                                                                        |
| POST   | /api/cart/merge          | Private                | ANY  | Body: guestSessionId                              | Merges a guest cart into the logged-in user's cart right after login — important so items survive the login flow.               |

## Orders & Payments

Backing tables: Order , OrderItem , Payment

| Method | Endpoint    | Auth            | Role | Params / Body                            | Description                                                                                                                                                                                                                          |
|--------|-------------|-----------------|------|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| POST   | /api/orders | Private         | USER | Body: shippingAddressId, paymentProvider | Checkout: converts current Cart / CartItem s into an Order / OrderItem s (snapshotting productTitleSnapshot , unitPrice ), computes subtotal/shippingFee/totalAmount , decrements variant stock, clears cart, and kicks off payment. |
| GET    | /api/orders | Private (Owner) | USER | Query: page, size, status?               | Lists the logged-in user's past orders — powers the account "Orders" tab.                                                                                                                                                            |

|       |                                  |                             |            |                                           |                                                                                                                                                                                                                                                                                                                 |
|-------|----------------------------------|-----------------------------|------------|-------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| GET   | /api/orders/{id}                 | Private (Owner or ADMIN)    | USER/ADMIN | Path: id                                  | Full order detail with line items and payment status — powers /order-details .                                                                                                                                                                                                                                  |
| PATCH | /api/orders/{id}/cancel          | Private (Owner)             | USER       | Path: id                                  | Cancels an order while it's still cancellable (e.g. status = PENDING), restocks variants.                                                                                                                                                                                                                       |
| GET   | /api/admin/orders                | Private                     | ADMIN      | Query: page, size, status?, userId?       | Admin order queue/search across all users.                                                                                                                                                                                                                                                                      |
| PATCH | /api/admin/orders/{id}/status    | Private                     | ADMIN      | Path: id;<br>Body: status                 | Admin transitions order status (e.g. CONFIRMED → SHIPPED → DELIVERED).                                                                                                                                                                                                                                          |
| POST  | /api/payments/{orderId}/initiate | Private (Owner)             | USER       | Path: orderId                             | Creates a Payment row and returns whatever the provider (Stripe/PayPal/etc.) needs to start checkout (client secret, redirect URL).                                                                                                                                                                             |
| POST  | /api/payments/webhook/{provider} | Public (signature verified) |            | Path: provider;<br>Body: provider payload | Receives asynchronous payment events from the payment provider. The webhook verifies the provider's signature, updates the payment status, records payment timestamps, and synchronizes the associated order status. Authentication is performed using the provider's webhook signature rather than a user JWT. |
| GET   | /api/payments/{orderId}/status   | Private (Owner)             | USER       | Path: orderId                             | Polls current payment status, useful while waiting on a redirect-based provider.                                                                                                                                                                                                                                |

## Recently View

Backing tables: recently\_viewed, Products

| Method | Endpoint                         | Auth            | Role | Params / Body   | Description                                                      |
|--------|----------------------------------|-----------------|------|-----------------|------------------------------------------------------------------|
| POST   | /api/recently-viewed/{productId} | Private (Owner) | USER | Path: productId | Records a product as recently viewed by the authenticated user.  |
| DELETE | /api/recently-viewed/{productId} | Private (Owner) | USER | Path: productId | Removes a specific product from the user's recently viewed list. |
| GET    | /api/recently-viewed             | Private (Owner) | USER |                 | Returns the authenticated user's recently viewed products.       |
| DELETE | /api/recently-viewed             | Private (Owner) | USER |                 | Clears all recently viewed products for the authenticated user.  |

## Checkout Summary

Backing tables: Products, Products Variants

| Method | Endpoint              | Auth               | Role | Params / Body                             | Description                                                                                    |
|--------|-----------------------|--------------------|------|-------------------------------------------|------------------------------------------------------------------------------------------------|
| POST   | /api/checkout/summary | Private<br>(Owner) | USER | Body:<br>selectedAddressId,<br>couponCode | Calculates and returns the checkout summary based on the selected address and optional coupon. |

### Products Filter Option

Backing tables: categories, Brands, Product Variants

| Method | Endpoint              | Auth   | Role | Params / Body | Description                                                                                      |
|--------|-----------------------|--------|------|---------------|--------------------------------------------------------------------------------------------------|
| GET    | /api/products/filters | Public |      | Query: slug?  | Returns the available filter options for products, such as categories, brands, and price ranges. |